

Mapeo de preguntas a requisitos normativos

Nº Pregunta	Tema principal	ISO 27001 / 27002 / 27005	NIST CSF / RMF	NIS2 / DORA / otros marcos UE
1.1-1.4	Contexto organizativo y partes interesadas	Cláusulas 4 y 5, Anexo A 5.1	ID.AM, ID.BE	NIS2 Art. 4-7 (entidades y obligaciones)
2.1-2.3	Marco de gestión de riesgos de ciberseguridad	6.1, 8.2, 8.3, ISO 27005 secciones 6-8	ID.RA, ID.GV, RMF pasos de preparación	NIS2 Art. 21; DORA Art. 5-6
3.1-3.4	Cuantificación FAIR y herramientas	6.1, 8.2 (metodologías de riesgo)	ID.RA-3, ID.RA-6	Énfasis en enfoque basado en riesgos (NIS2)
4.1-4.5	Modelado de amenazas STRIDE	A.8.28, A.5.7, ISO 27005 (identificación)	ID.RA; PR.IP-12	Gestión de riesgos técnicos (NIS2, DORA)
5.1.x	Autenticidad	A.5.15, A.5.17, A.8.2	PR.AC-1, PR.AC-6	Requisitos de autenticación robusta
5.2.x	Integridad	A.5.10, A.8.9	PR.DS-6, PR.DS-7	Integridad de datos y registros
5.3.x	No repudio	A.8.11, A.8.15	PR.PT-1, PR.DS-1	Evidencias de transacciones y trazabilidad
5.4.x	Confidencialidad	A.5.10, A.5.12, A.8.24	PR.DS-1, PR.AC-3	Protección de datos, brechas y notificación
5.5.x	Disponibilidad	A.5.30, A.8.14, A.8.16	PR.PT-5, PR.IP-9	Resiliencia de servicios esenciales
5.6.x	Autorización y privilegios	A.5.15, A.8.2, A.8.3	PR.AC-4, PR.AC-5	Gestión de accesos privilegiados
6.1-6.3	Zero Trust y segmentación	A.5.7, A.5.19, A.8.23	PR.AC, PR.PT, DE.CM	Arquitecturas seguras y segmentación
7.1-7.4	Resiliencia, continuidad y seguros	Cláusula 6.1, A.5.30, A.5.31, A.5.32	ID.BE-5, PR.IP-9, RC.IM-1	DORA resiliencia operativa digital, NIS2 Art. 21
8.1-8.3	Datos de incidentes y gobierno	A.5.8, A.5.36, A.8.16	DE.AE, RS.AN, ID.GV	Reporte de incidentes y supervisión
9.1-9.3	Enfoque normativo y actualización de modelos	Cláusula 4, 6, 9	ID.GV, GV-3	Cumplimiento y revisión continua

10.1-10.4	Talento, cultura y mejora continua	Cláusula 7 (competencia, concienciación)	ID.GV, PR.AT, IM-1	Requisitos de gobernanza y cultura de seguridad
-----------	------------------------------------	--	--------------------	---

Nota: las referencias son orientativas y deben adaptarse a la versión específica de las normas aplicables y a las interpretaciones de cada organismo regulador.